Informe de seguridad del frontend

PharmaSoft · SPA segura, aviso de expiración y Mi cuenta

Kevin Eduardo Del Carpio Alegría · Lenguaje de Programación II · Ciclo IV · 2026-2

C1. Resumen de ejecución

La validación del 25 de octubre comprende 26 casos: los 16 base, cuatro propios de grupos distintos (L-05, S-05, G-03 y M-03), los cuatro del aviso previo y dos de Mi cuenta. Se contrastaron autenticación, sesión, solicitudes HTTP, navegación y permisos con el comportamiento esperado. Los rechazos 401 y 403 previstos se registran como Pasa.

Grupo	Ejecutados	Pasa	Falla
Login	5	5	0
Sesión	5	5	0
Interceptores	3	3	0
Guards	3	3	0
Menú y acciones	3	3	0
401 / 403	1	1	0
Aviso de sesión	4	4	0
Mi cuenta	2	2	0
Total	26	26	0

El alcance utiliza las cuentas admin, vendedor, almacen, supervisor e inactivo. Las referencias E de la matriz identifican la secuencia de cada comprobación. La compilación de producción y las 137 pruebas automatizadas aprobadas complementan esta validación; no se cuentan como casos manuales.

Aviso previo a la expiración

AuthService.segundosRestantes se actualiza cada segundo; porVencer se activa con 120 segundos restantes o menos. AvisoSesion presenta mm:ss sobre el contenido con role="status". Las pruebas B usan un login de 180 s: se observa 01:56 y después 01:09; × oculta el aviso y el vencimiento sigue activo. Una sesión nueva vuelve a permitir el aviso y el cierre inmediato. No se renueva el token ni se prolonga expiraEn.

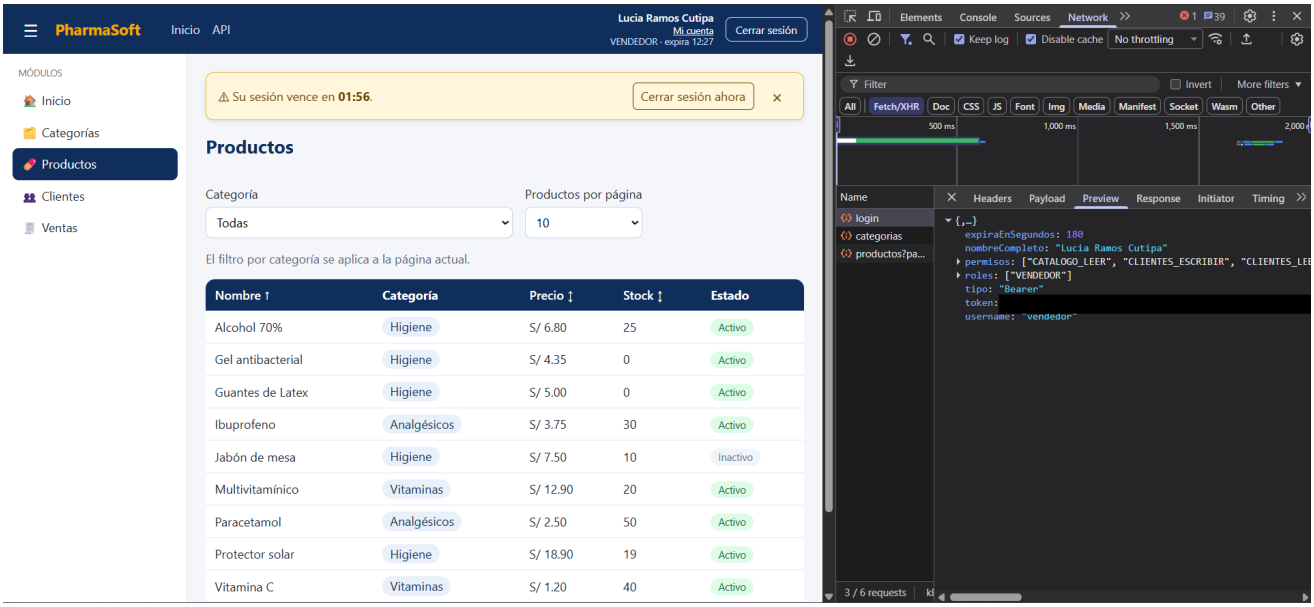


Figura 1. B-01: aviso previo con 01:56 restantes y duración de emisión de 180 segundos. Referencia E063.

Perfil y resultados de seguridad

Mi cuenta y cambios de permisos

La ruta /mi-cuenta se carga con loadComponent dentro del layout, protegida por authGuard sin permisoGuard. AuthService.obtenerPerfil() consulta GET /api/v1/auth/me y adapta empleadoNombre al nombre mostrado. MiCuenta.cargar() gestiona carga, error y reintento. Los roles aparecen como etiquetas y los ocho permisos se distribuyen entre Catálogo, Clientes, Ventas, Reportes y Usuarios.

C-01 contrasta los perfiles de los cuatro usuarios activos; C-02 bloquea auth/me, conserva la sesión y recupera el perfil al reintentar. G-03 confirma el acceso de almacén y la redirección anónima. En M-03, al añadir temporalmente ALMACENERO a vendedor, permisosCambiaron compara el servidor con la sesión anterior y muestra la advertencia; el menú y encabezado mantienen esa sesión. Restaurar VENDEDOR y actualizar el perfil elimina el aviso.

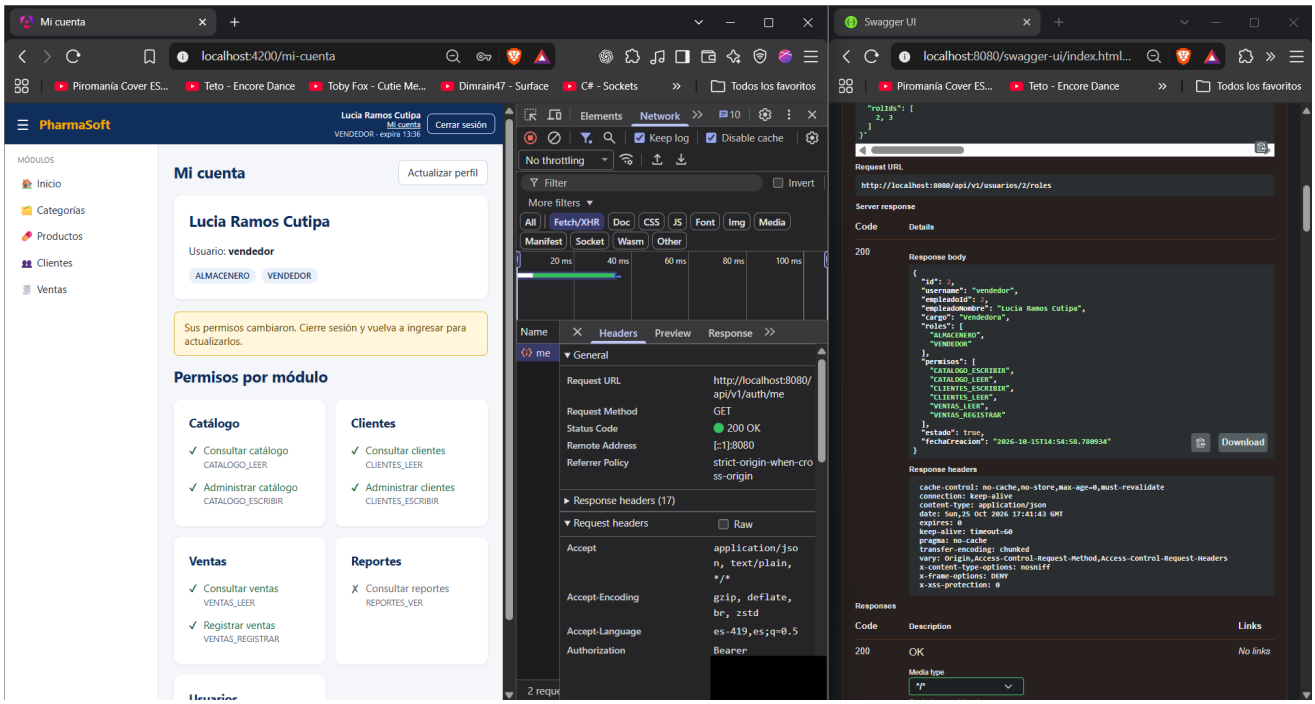


Figura 2. M-03: el servidor devuelve ambos roles y Mi cuenta advierte del cambio; el encabezado mantiene VENDEDOR. Referencia E081.

C2. Hallazgos de la validación

No se observaron casos fallidos en los comportamientos registrados; por ello no corresponden fichas de defectos con severidad, causa y corrección. El error de conexión provocado en I-02, el 401 de I-03, los bloqueos de G-02 y el 403 de E-01 son resultados esperados. En I-02 se reintentan por separado Productos y Categorías hasta recuperar ambos listados.

Observación S-04. Después de cerrar sesión en una pestaña, la otra mantiene su propia sesión y puede navegar. AuthService.cerrarSesion() elimina únicamente el sessionStorage de su contexto. Esta independencia es coherente con el almacenamiento elegido; en una computadora compartida puede dejar otra pestaña autenticada. Si se requiere logout coordinado, propondría emitir un mensaje con BroadcastChannel y hacer que cada pestaña ejecute cerrarSesion(), evitando depender del evento storage de sessionStorage entre pestañas.

La duración normal se recupera tras las pruebas: C-01 muestra expiraEnSegundos: 3600. M-03 termina con vendedor restaurado al rol original y sin advertencia después de actualizar. Las evidencias del 403 también conservan Alcohol 70% activo y con stock 25.

C3. Análisis de seguridad

1. Autorización efectiva en el backend

El menú, la directiva y los guards orientan la navegación, pero el navegador está bajo control de quien lo utiliza. Es posible invocar el componente desde la consola o construir una petición aunque el botón esté oculto. En E-01 se llamó ProductoList.darDeBaja() desde Angular como vendedor: el servidor rechazó DELETE /api/v1/productos/21 con 403, la SPA mostró el mensaje y el producto siguió activo (E059-E061). La validación de permisos del backend impide que manipular la interfaz autorice una operación; *appSiPermiso y permisoGuard mejoran la experiencia, mientras el servidor decide el acceso a los datos.

2. Almacenamiento del token en la botica

sessionStorage permite conservar la sesión tras F5 y limita su persistencia al contexto de la pestaña; localStorage la mantiene entre aperturas y comparte el mismo origen entre pestañas, lo que aumenta la permanencia del acceso en equipos compartidos. Ambos son accesibles a JavaScript y un XSS podría extraer el token. Una cookie HttpOnly impide leerla desde JavaScript, aunque exige un diseño de autenticación mediante cookies, HTTPS, atributos Secure/SameSite y protección CSRF cuando corresponda. Para el backend Bearer actual mantendría sessionStorage, como implementa AuthService.leerSesionGuardada(), con vencimiento y logout explícito; para una evolución productiva elegiría una cookie HttpOnly con esos controles. S-04 demuestra la necesidad de considerar también otras pestañas abiertas.

3. Diferencia entre 401 y 403

errorInterceptor, en core/interceptors/error-interceptor.ts, cierra la sesión ante un 401 de la API protegida porque la credencial ya no permite autenticar la petición; excluye auth/login, donde el formulario debe comunicar credenciales incorrectas. I-03 evidencia ese cierre y el retorno a Ventas (E040-E042). Un 403 indica una operación no autorizada para una identidad reconocida: se propaga al componente sin limpiar la sesión, como muestra E-01. Invertirlos dejaría al usuario atrapado con una credencial inválida tras un 401 y lo expulsaría innecesariamente cada vez que intentara una acción sin permiso.

4. Redirección abierta y returnUrl

Una redirección abierta acepta un destino controlado por terceros y lleva al usuario a otro sitio después de autenticarse, facilitando el engaño. Login.destino(), en features/auth/pages/login/login.ts, acepta únicamente rutas que comienzan por / y rechaza // y barras invertidas; los demás valores caen en /inicio. L-04 solicita https://sitio-falso.com y termina en localhost:4200/inicio (E014-E015). Así se conserva el retorno a páginas internas, como /ventas, sin convertir el parámetro en una salida hacia un dominio externo.

Conclusión

Los resultados registrados son conformes con los casos de seguridad evaluados. La SPA avisa antes del vencimiento, limpia la sesión al expirar, diferencia autenticación de autorización y permite consultar el perfil vigente del servidor sin reemplazar silenciosamente la sesión. La matriz conserva los resultados de cada caso y las evidencias agrupadas permiten repetir su comprobación.